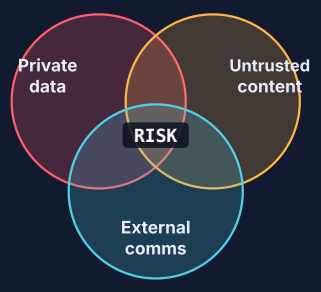
// THREAT BRIEFING · AUTUMN 2026

AI Security: when the model acts, the prompt is the exploit.

AI has moved from chatbots to **agents that read, decide and execute**: browsing, writing code, calling tools and holding credentials. The attack surface moved with it. Here's what changed and how to defend.

The "lethal trifecta"

Any agent that combines all three can be tricked into leaking data. Remove one leg and the exfiltration path closes.



01 How agents get hijacked: anatomy of an indirect prompt injection

The attacker never talks to the model. They plant text where the agent will read it, then let the agent's own permissions do the work.

STEP 1 — Plant
Hidden instructions go into a web page, email, PDF, ticket, README or tool description.

BREAK IT: Label and isolate untrusted inputs; strip hidden text and markup.

STEP 2 — Ingest
The agent retrieves it while doing a normal task: summarise, triage, fix a bug.

BREAK IT: Limit what each task may read. Don't let one agent see everything.

STEP 3 — Hijack
The model treats the data as instructions, and its goal quietly changes.

BREAK IT: Plan before reading; a planner never sees the raw content.

STEP 4 — Act
It calls tools using *its* credentials: reads secrets, runs code, edits repos.

BREAK IT: Least-privilege, short-lived tokens; sandbox all code execution.

STEP 5 — Exfiltrate
Data leaves via a link, an image URL, a commit, an API call or a public PR.

BREAK IT: Egress allow-lists; human sign-off for outbound and irreversible actions.

02 What's new on the threat landscape

TOOLING

MCP & tool poisoning

Every MCP server is a new trust boundary. Poisoned tool descriptions and outputs carry hidden instructions. In **"agentjacking"** (CSA, June 2026), planted error reports led coding agents to run attacker code. MCP still has **no signing standard**.

OFFENCE

AI-orchestrated intrusions

Attackers use agents for recon, exploitation and lateral movement. In late 2025 Anthropic disclosed a state-backed campaign where **an AI agent ran most of the intrusion** itself. Expect machine-speed attacks.

VULNERABILITY RESEARCH

AI finds the bugs first

Frontier models now find **critical flaws in widely used open-source code**, which shrinks the time from discovery to exploit. Defenders need the same tools and faster patch cycles.

SUPPLY CHAIN

Poisoned models, skills & packages

Backdoored weights, malicious agent plugins and **"slopsquatting"**: attackers register package names that LLMs hallucinate. Your AI bill of materials is now part of your attack surface.

IDENTITY

Agents as privileged insiders

Agents hold **standing API keys, OAuth tokens and service accounts**, often in plaintext config. An over-scoped agent hands an attacker a ready-made insider.

PERSISTENCE

Memory & context poisoning

Memory and RAG stores let one injection **persist across sessions and users**. In multi-agent pipelines, one compromised agent can cascade bad instructions downstream.

03 OWASP Top 10 for Agentic Apps

ASI01 Agent Goal Hijack — injected goals redirect the agent	**ASI02** Tool Misuse & Exploitation — legit tools, harmful use	**ASI03** Identity & Privilege Abuse — inherited or escalated creds	**ASI04** Agentic Supply Chain — tools, models, MCP servers	**ASI05** Unexpected Code Execution — agent-generated RCE
ASI06 Memory & Context Poisoning — persistent corruption	**ASI07** Insecure Inter-Agent Comms — spoofed or tampered messages	**ASI08** Cascading Failures — one fault, many agents	**ASI09** Human-Agent Trust Exploitation — persuasive bad advice	**ASI10** Rogue Agents — drift beyond intended scope

OWASP GenAI Security Project, released Dec 2025. Peer-reviewed by 100+ practitioners.

04 Defender's playbook

- **Assume injection succeeds.** Limit how much damage a hijacked agent can do.
- **Break the trifecta.** No agent gets private data, untrusted input *and* an outbound channel.
- **Least privilege, per task.** Scoped, short-lived credentials, with one identity per agent.
- **Sandbox execution.** Isolated containers, no secrets, default-deny egress.
- **Human approval** for payments, deletions, deployments and external messages.
- **Vet the AI supply chain.** Pin MCP servers, plugins and models; keep an AI-BOM.
- **Log every tool call.** Trace prompts, inputs and outputs so you can detect and investigate.
- **Red-team continuously.** Adaptive injection tests in CI, mapped to MITRE ATLAS.
- **Turn AI on your own code** and find the bugs before attackers do.

Frameworks to know: EU AI Act (GPAI duties since Aug 2025; further obligations phasing in) · NIST AI RMF + GenAI Profile · MITRE ATLAS · ISO/IEC 42001 · OWASP LLM & Agentic Top 10s.

Sources: OWASP Top 10 for Agentic Applications 2026 (genai.owasp.org) · Cloud Security Alliance research notes on MCP agentjacking and coding-agent repository poisoning (June 2026) · Anthropic threat intelligence report on an AI-orchestrated espionage campaign (Nov 2025) · S. Willison, "The lethal trifecta for AI agents" (2025) · MITRE ATLAS · NIST AI 100-1 / 600-1 · EU AI Act (Reg. 2024/1689). Specific figures change quickly, so check primary advisories before acting.